Engineering practice survey

Fifteen questions, answered once per release train, inventory the SBOM, signing, update, testing, release-gate and vulnerability-intake practice that the shared-platform workstream must build or extend (EUR 955k one-off before contingency).

Design

One response per release train records the starting point for each platform service, so the shared-platform budget is sized from facts rather than estimates.

Item	Design
Purpose	Size the shared-platform workstream: how many release trains need each platform service, and from what starting point
Unit of analysis	Release train: a pipeline that builds and ships one or more SKUs; a family with several trains answers once per train
Respondents	Engineering lead of each release train (census), at least one per family, so 13 or more responses
Timing	9–27 Nov 2026; sizing note by 4 Dec 2026, in the first week of Phase 2
Length	15 questions, about 10 minutes
Owner	Head of platform engineering, with the product security officer
Data protection	Reported by release train, never by person; no vulnerability details
Cross-check	Answers are compared with the family's diagnostic scores on Q4.1, Q4.2, Q5.1, Q6.1 and Q7.1; differences go to moderation

Questions

Questions 1 to 4 describe the train and are not scored; questions 5 to 14 score 0 to 2, with points in brackets; question 15 is open. All but question 15 are required.

ENG-01 Which product family and release train does this response cover? *Family: list of the 13 families. Release train: text.*

ENG-02 How many releases did this train ship to customers in the last 12 months? *Single choice.*

- None
- 1 to 2
- 3 to 6
- 7 to 12
- More than 12

ENG-03 What does this train ship? *Multiple choice.*

- Embedded firmware on a real-time operating system
- Embedded Linux image
- Mobile app
- Desktop software
- Cloud service that a product function relies on
- SDK or library

ENG-04 Which CI system builds the shipped artefact? *Single choice.*

- GitLab CI
- GitHub Actions
- Jenkins
- Azure DevOps
- Other (please specify)
- Built manually

ENG-05 How is the SBOM for this train generated today? *Single choice.*

- Automatically at build, from the shipped artefact (2)
- Automatically at build, from source manifests (1)
- By a separate scan after the build (1)
- Manually (0)
- No SBOM is generated (0)
- Don't know (0)

ENG-06 Which SBOM format and version does the train produce? *Single choice.*

- CycloneDX 1.6 or later (2)
- SPDX 3.0.1 or later (2)

- An earlier CycloneDX or SPDX version (1)
- Another format (0)
- None (0)
- Don't know (0)

ENG-07 Are SBOMs signed and stored with each release? *Single choice.*

- Signed and stored with the release (2)
- Stored, not signed (1)
- Neither (0)
- Don't know (0)

ENG-08 Is binary software composition analysis run on the final firmware or image, not only on manifests? *Single choice.*

- On every release (2)
- On some releases (1)
- Never (0)
- Not applicable: the train ships no binary image (not scored)
- Don't know (0)

ENG-09 Is every release checked against known exploited vulnerabilities (CISA KEV, EUVD) before it ships? *Single choice.*

- Automatically, and a finding blocks the release (2)
- Automatically, without blocking (1)
- Manually (1)
- No (0)
- Don't know (0)

ENG-10 Where are the release-signing keys held? *Single choice.*

- In an HSM (2)
- In a hardware-backed cloud key-management service (2)
- In software on build servers (1)
- On developer machines (0)
- Releases are not signed (0)
- Don't know (0)

ENG-11 Which protections does the update mechanism have? *Multiple choice.*

- Signature verified before install
- Anti-rollback

- Atomic install with recovery after a failed install
- Automatic security updates on by default
- User notification of updates
- None of these
- Don't know

Points: 2 if the first three protections are all present, 1 if one or two of them are, 0 otherwise. The last two are recorded for Q7.2 of the diagnostic.

ENG-12 How often are externally reachable interfaces, such as parsers and protocol handlers, fuzz-tested? *Single choice.*

- Continuously in CI (2)
- On every release (2)
- At least once a year (1)
- Never (0)
- Don't know (0)

ENG-13 Does a release need a signed security gate record before it can be tagged? *Single choice.*

- Yes, enforced by tooling (2)
- Yes, by procedure only (1)
- There is no gate (0)
- Don't know (0)

ENG-14 How do vulnerability reports from outside the company reach your team today? *Single choice.*

- Through PSIRT, with a case number (2)
- From customers or support, case by case (1)
- Through a public issue tracker (1)
- There is no defined route (0)
- Don't know (0)

ENG-15 Which shared platform service would most reduce your team's CRA effort, and why? *Open text, optional.*

Analysis

The practice score shows each train's starting point, and the sizing matrix turns the gaps into onboarding counts for each platform service.

- **Practice score.** Points divided by the maximum for the scored questions that apply: 20 points across ENG-05 to ENG-14, or 18 when ENG-08 does not apply. Reported by family and BU, never as a ranking of people.
- **Consistency check.** A train scoring 2 on ENG-05 and ENG-07 while its family scores below 3 on Q5.1 is flagged for moderation, and the reverse case too.

Sizing matrix (shell, filled after fieldwork)

Platform service	A train needs it when	Trains needing it	Of which Wave 1	Milestone or budget line
SBOM generation at build	ENG-05 or ENG-06 below 2	[ ]	[ ]	M8: SBOM pipeline live on all Wave 1 release trains, 31 Mar 2027
SBOM signing and storage	ENG-07 below 2	[ ]	[ ]	K07: every release with a signed SBOM by 31 Mar 2027
Binary composition analysis	ENG-08 below 2	[ ]	[ ]	Issue I03, due 15 Jan 2027
Known-exploitable release check	ENG-09 below 2	[ ]	[ ]	Release gate (WS4)
HSM signing service	ENG-10 below 2	[ ]	[ ]	M10: update infrastructure hardened, 30 Jun 2027
Update hardening	ENG-11 below 2	[ ]	[ ]	M10
Fuzzing harness	ENG-12 below 2	[ ]	[ ]	Security testing line, EUR 660k in 2027
Release gate tooling	ENG-13 below 2	[ ]	[ ]	Release gate (WS4)
PSIRT intake	ENG-14 below 2	[ ]	[ ]	WS3 Reporting and PSIRT

The sizing note prices the matrix against the shared-platform line: EUR 212.5k in Q4 2026 and EUR 742.5k in 2027 (EUR 955k one-off before contingency), then EUR 210k a year to run from 2028.

Benchmarks from the ENISA SBOM State of Play 2026 (RD07, official survey of 334 respondents):

Measure from this survey	Benchmark
Share of trains generating SBOMs automatically (ENG-05, first three options)	74% of 334 respondents have partly or fully automated SBOM generation (ENISA SBOM State of Play 2026)
Share of trains generating at build (ENG-05, first two options)	39% generate at build
Format split (ENG-06)	44% CycloneDX, 29% SPDX
Trains without binary composition analysis (ENG-08), a proxy for completeness gaps	62% name completeness as the top challenge

The build pipeline, not this survey, remains the source for K07: signed SBOMs on 9 of the last 24 releases (38%) on 30 Oct 2026.

Project Rampart · Survey and Interview Instruments (D07) · Illustrative · 31 Oct 2026